Pericope ERM - Master Demo Runbook & Defense Guide

Major Project Authors: Srivatsan B (1AT23CG104), Raja Vishnu (1AT23CG080), Rithvik R (1AT23CG084), Niranthar M Javagal (1AT23CG071)

Academic Guide: Prof. Veena S, Department of Computer Science & Engineering, Atria Institute of Technology

Version: 3.2 (Production & Defense Edition)

1. Executive Summary & Product Positioning

Academic Defense Positioning:

> *Pericope ERM is a three-tier, resilience-first web application for full-lifecycle Enterprise Risk Management (ERM). It digitizes risk identification, qualitative/quantitative scoring, control mitigation, KRI telemetry, maker-checker approval workflows, and immutable audit logging over an Oracle Autonomous Database via Oracle REST Data Services (ORDS). The core contribution lies in its dual mathematical risk model (S = L x I and Single Loss Expectancy SLE = S x $10,000), an in-memory shadow store fallback architecture, and a database hardening layer with autonomous transactions.*

Enterprise Client Value Proposition:

> *Most mid-sized organizations manage critical risk registers out of disconnected Excel spreadsheets and email chains. This creates compliance blindspots, untracked residual risk, and failed SOX/ISO audits. Pericope ERM automates the entire RCSA workflow, allows 1-click migration of your existing Excel risk registers, gives real-time telemetry alerts on operational threshold breaches, and exports board-ready risk packs in 1 click.*

2. Pre-Demo Technical Checklist (5-Minute Setup)

- **Step 1: Start Backend BFF Server (Port 5000):**

```
node server.js
```

Output Confirmation: `Pericope ERM BFF API on http://localhost:5000 | Upstream ORDS: 48 endpoints ready`

- **Step 2: Start Frontend Application (Port 3000):**

```
npm run dev
```

Open Browser: `http://localhost:3000`

- **Step 3: Run Automated QA Test Suite (Proof of Verification):**

```
node qa_test_suite.mjs
```

Result: **12/12 Passed** (Validates mathematical bounds, FAIR Monte Carlo math, anti-junk sanitizers, ORDS normalizers, and local storage CRUD engines).

3. Track A: Academic Major Project Defense (20 Minutes)

Timeline	Phase & Screen	Key Technical Points to Explain
:---	:---	:---
0:00 - 3:00	**1. Problem Statement & Motivation**	• Spreadsheets lack segregation of duties, audit trails, and automated residual calculations. • Commercial tools (ServiceNow, RSA Archer) cost $50k+/year and take months to deploy. • Pericope ERM bridges this gap with a single-schema, three-tier cloud-native design.
3:00 - 7:00	**2. 3-Tier Resilient Architecture**	• **Tier 1 (Client):** Next.js 15 App Router + TanStack Query caching + LocalStore offline engine. • **Tier 2 (BFF API):** Node.js Express proxy with 8s bounded timeout, keyboard-mash sanitization, and in-memory shadow store fallback. • **Tier 3 (Database):** Oracle Autonomous Database (ADW) exposed through ORDS REST endpoints.
7:00 - 11:00	**3. Mathematical Scoring Engine**	• **Qualitative Model:** S = L x I in [1, 25] mapped to 4 severity bands. • **Quantitative Exposure:** SLE = S x $10,000 (Single Loss Expectancy in USD). • **Multi-Factor Residual Formula:** eta = (Design x Operating) / 25, calculating actual risk reduction. • **FAIR Monte Carlo Simulation:** 10,000 iterations computing Annualized Loss Expectancy (ALE) and 95% Value at Risk (VaR).
11:00 - 15:00	**4. Database Hardening & Remediation**	• Show `db/fix_pericope_erm.sql`. • Explain how ORA-04098 invalid trigger was resolved using **autonomous transactions (PRAGMA AUTONOMOUS_TRANSACTION)** so audit logging never aborts business DML. • Explain sequence auto-resync (STEP 6B) preventing ORA-00001 PK collision.
15:00 - 18:00	**5. RBAC & SOX 404 Auditability**	• Show `X-User-*` header attribution. • Demonstrate live role switching: **Auditor (Lin Wei)** gets read-only view with immutable audit log; **Manager (Priya Sharma)** has approval authority.
18:00 - 20:00	**6. Conclusion & Viva Q&A**	• Summarize research paper findings, performance benchmarks, and answer panel questions.

4. Track B: Enterprise Client Sales Demo (15 Minutes)

Timeline	Phase & Screen	Client Value Proposition
:---	:---	:---
0:00 - 2:00	**1. Executive Cockpit (/dashboard)**	*"Here is the Executive Dashboard showing gross financial exposure ($SLE), control effectiveness (78%), and active RCSA cycles at a glance."*
2:00 - 5:00	**2. Excel / CSV Migration (/rcsa/identification)**	*"You don't need to rebuild your registers. Download our CSV template or upload your existing spreadsheets directly into Pericope with instant validation."*
5:00 - 8:00	**3. 5x5 Heatmap & Residual Step-down (/heatmaps)**	*"Watch how risks are plotted across likelihood and impact. Switch between Inherent, Residual, and Trend views to see how internal controls reduce monetary exposure."*
8:00 - 11:00	**4. Continuous KRI Telemetry (/kri)**	*"Simulate an operational spike in IT outage hours from 4.0 to 14.5. Watch the indicator turn Red, trigger an alert, and log an immutable audit event."*
11:00 - 13:00	**5. SOX 404 RBAC & Audit Trail (/audit-trail)**	*"Demonstrate Segregation of Duties. Switch to Auditor persona — notice all create/delete buttons disappear and the full historical event log is accessible."*
13:00 - 15:00	**6. 1-Click Board Risk Pack (/reports)**	*"Click 'Print / Save as PDF' on the Executive Board Pack to generate a formatted quarterly risk committee deck."*

5. Click-by-Click Live Demonstration Script

Scene 1: Multi-Mode Corporate Sign-In

- Navigate to `http://localhost:3000`. If logged in, click user menu → **Sign out**.
- **Talking Point:** *"Pericope supports standard corporate credentials, Enterprise SSO, and one-click role persona testing."*
- Click **"Srivatsan B — Administrator"** or sign in with `srivatsan@pericope.local` / `Demo123!`.

Scene 2: Executive Dashboard

- Land on `/dashboard`.
- Point to the **4 KPI Panels**:
- **Active Risks:** 18
- **Single Loss Expectancy (SLE):** $1,280k
- **Control Coverage:** 78.4%
- **Assessment Completion:** 67%
- Hover over the **Trailing Risk Velocity** 6-month area chart.
- Point to the **Recent Risk Entries** ledger table with direct navigation links.

Scene 3: RCSA Lifecycle & Bulk Spreadsheet Migration

- Click **RCSA Hub** → **01 Setup** (`/rcsa/provisioning`).
- Point to the Stepper Bar: `01 Setup` → `02 Identify` → `03 Mitigation` → `04 Monitoring`.
- Click **"Demo starter packs"** → select **"Fintech & Banking Pack"** to demonstrate instant industry seeding.
- Click **"Next Stage: Identify →"** or open `/rcsa/identification`.
- Click **"CSV Template"** → browser downloads `pericope_risk_register_template.csv`.
- Click **"Import CSV"** → select any sample `.csv` → preview table displays parsed statements, likelihood, impact, and SLE.
- Click **"Import Risks"** → toast confirms successful bulk import into database.

Scene 4: Interactive 5x5 Risk Heatmap

- Navigate to **Risk Analytics** → **5x5 Risk Heatmaps** (`/heatmaps`).
- Point out the clear coordinate axes:
- **Y-Axis (Likelihood):** `5 - Almost Certain` down to `1 - Rare`.
- **X-Axis (Impact):** `1 - Insignificant` up to `5 - Severe`.
- Toggle between **Inherent Exposure**, **Residual (Post-Control)**, and **Risk Velocity**.
- Click on any active cell with numbers → dialog modal opens listing the exact risk scenarios mapped to that score.

5. Live Demonstration Script (Continued)

Scene 5: Continuous KRI Telemetry & Breach Alert Simulation

- Navigate to **Key Risk Indicators** (`/kri`).
- Point to the 4 operational metric cards (*Tracked indicators, Normal, Warnings, Red Breaches*).
- Find **"Unplanned IT Outage Hours"** (current value: 7.2 hrs/mo, status: Amber).
- Click the **Refresh/Update icon** → input value `14.5` → click **Update**.
- **Observe:**
- Status badge turns **Critical** / **Breach (Red)**.
- The mini trend line plots the new peak above the red reference line.
- Audit trail automatically captures the event.

Scene 6: Role-Based Access Control (RBAC) & Auditor Mode

- Open the top-right User Dropdown menu.
- Click **"Lin Wei (Auditor)"**.
- **Observe:**
- Amber banner appears: *"Auditor mode (read-only): You have view access to all records, control workpapers, and the audit log."*
- Navigate to `/rcsa/identification` or `/control-library` → notice that "+ Add Risk", "New control", and "Delete" buttons are hidden or disabled.
- Navigate to **Audit Trail** (`/audit-trail`).
- Point to the chronological table showing timestamps, actor names, action types (`CREATE`, `UPDATE`, `ROLE_CHANGE`), and results.
- Click **"Export CSV"** → exports complete compliance log.

Scene 7: 1-Click Executive Board Risk Report (PDF)

- Switch back to **Administrator** or navigate to **Reports** (`/reports`).
- Select **"Executive Board Risk Committee Pack"** (or click through any of the 8 dynamic reports in the catalog).
- Point out the 4 structured reporting sections:
- *1. Executive Exposure Summary*
- *2. Top High-Exposure Risk Scenarios Table*
- *3. Key Risk Indicator (KRI) Operational Thresholds*
- *4. SOX 404 & ISO 31000 Certification Sign-off*
- Click **"Print** / **Save as PDF"**.
- **Point out:** The print preview strips all browser navigation, buttons, and sidebars, rendering only the clean, full-width executive report.

6. Anticipated Viva & Client Questions with Model Answers

Q1 (Academic): How does your system achieve resilience if the Oracle Database/ORDS is slow or unreachable?

> ***Answer:*** *"Pericope ERM implements an in-memory shadow store inside the Node.js BFF (`server.js`). Upstream ORDS requests have a strict 8-second timeout. If ORDS times out or fails, the BFF transparently answers from the shadow store with synthetic UUIDs, ensuring the user interface never freezes. When connectivity is restored, records reconcile. Additionally, local-first modules in `lib/localStore.ts` utilize browser localStorage with cross-tab event listeners to maintain offline functionality."*

Q2 (Academic): Why did you choose a dual qualitative and quantitative risk scoring model?

> ***Answer:*** *"Most enterprises struggle because qualitative 5x5 heatmaps and quantitative dollar estimates are maintained in separate spreadsheets and drift out of sync. In Pericope ERM, every risk entry takes ordinal Likelihood L in [1,5] and Impact I in [1,5], computing the qualitative score S = L x I and the financial exposure SLE = S x $10,000 simultaneously. When controls are mapped, the multi-factor effectiveness factor eta = (Design x Operating)/25 steps down both the heatmap cell and the monetary exposure together."*

Q3 (Client): We have 200+ risks in Excel right now. How difficult is it to migrate to Pericope?

> ***Answer:*** *"You can migrate in less than 2 minutes. On the Risk Identification screen, click 'CSV Template' to download our pre-mapped format, paste your columns, and click 'Import CSV'. The system parses the records, validates the data, calculates the SLE exposures, and populates your live register immediately."*

Q4 (Academic / Security): How do you enforce Segregation of Duties (SoD) and audit compliance?

> ***Answer:*** *"Every mutating request passes through authentication middleware that attaches user identity headers (X-User-Id, X-User-Name, X-User-Role). The backend enforces server-side role permissions where only Administrators can perform destructive deletes or manage users, Risk Managers approve mitigations, and Auditors are restricted to read-only access. Every event is written using Oracle autonomous transaction triggers (ERM_AUDIT_WRITE) that cannot be rolled back or aborted by business errors."*

7. System Architecture & Quantitative Formula Cheat-Sheet

1. Qualitative Composite Score:

```
S = L × I      L, I ∈ \{1, 2, 3, 4, 5\}    ⇒    S ∈ [1, 25]
```

- **Low:** 1 ≤ S ≤ 7
- **Medium:** 8 ≤ S ≤ 11
- **High:** 12 ≤ S ≤ 15
- **Critical:** 16 ≤ S ≤ 25

2. Single Loss Expectancy (SLE):

```
SLE = L × I × \$10{,000    (USD)
```

3. Multi-Factor Control Effectiveness & Residual Risk:

```
\eta = {Design Effectiveness (1–5) × Operating Effectiveness (1–5)}{25 ∈ [0.04, 1.0]
```

```
L_{res = \max\left(1, \; round\left(L_{inh × (1 − 0.7 × \eta)\right)\right)
```

```
I_{res = \max\left(1, \; round\left(I_{inh × (1 − 0.5 × \eta)\right)\right)
```

```
Residual SLE = L_{res × I_{res × \$10{,000
```

4. FAIR Monte Carlo Loss Distribution (10,000 Iterations):

- **Loss Event Frequency (LEF):** Modeled via Poisson Distribution (λ = (L / 5) * 2.5).
- **Loss Magnitude (LM):** Modeled via Lognormal Distribution derived from SLE.
- **Output Metrics:** Annualized Loss Expectancy (ALE) and 95% Value at Risk (VaR 95).

5. Architectural Verification:

- **Frontend:** Next.js 15 App Router · React 19 · Tailwind CSS · TanStack Query
- **BFF Layer:** Node.js Express API · Bounded 8s Timeout · In-Memory Shadow Store
- **Database:** Oracle Autonomous Database (ADW) · ORDS REST Gateway · PL/SQL Autonomous Triggers